

Enhanced Attack Report

Smooth Operator

Generated on 2025-10-07

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: Smooth Operator

Malware Description: • Smooth Operator malware targets the macOS operating system. • Smooth Operator was distributed to victims as part of the 3CX supply chain attack. • The infected software package was signed by 3CX and notarized by Apple. • HTTPS is used as a C2 channel, with an additional custom encoding algorithm used to obfuscate exfiltrated data. • Smooth Operator randomises the C2 server it communicates with. The 3CX website is included in the list of C2 Servers it can beacon to. • Malicious code inserted into a dynamic library (dylib) packaged with the 3CX software, downloads and runs a second stage payload.

Quick Overview

Milestone m1

a1. Supply Chain Compromise: Compromise Software Dependencies and Development Tools as used by the malware (T1195.001)

Milestone m2

a2. Compromise Client Software Binary as used by the malware (T1574.001)

Milestone m3

a3. Deobfuscate/Decode Files or Information as used by the malware (T1140)

a4. Indicator Removal: File Deletion as used by the malware (T1070.010)

a5. Virtualization/Sandbox Evasion: Time Based Evasion as used by the malware (T1497.003)

Milestone m4

a6. Automated Collection as used by the malware (T1005)

Milestone m5

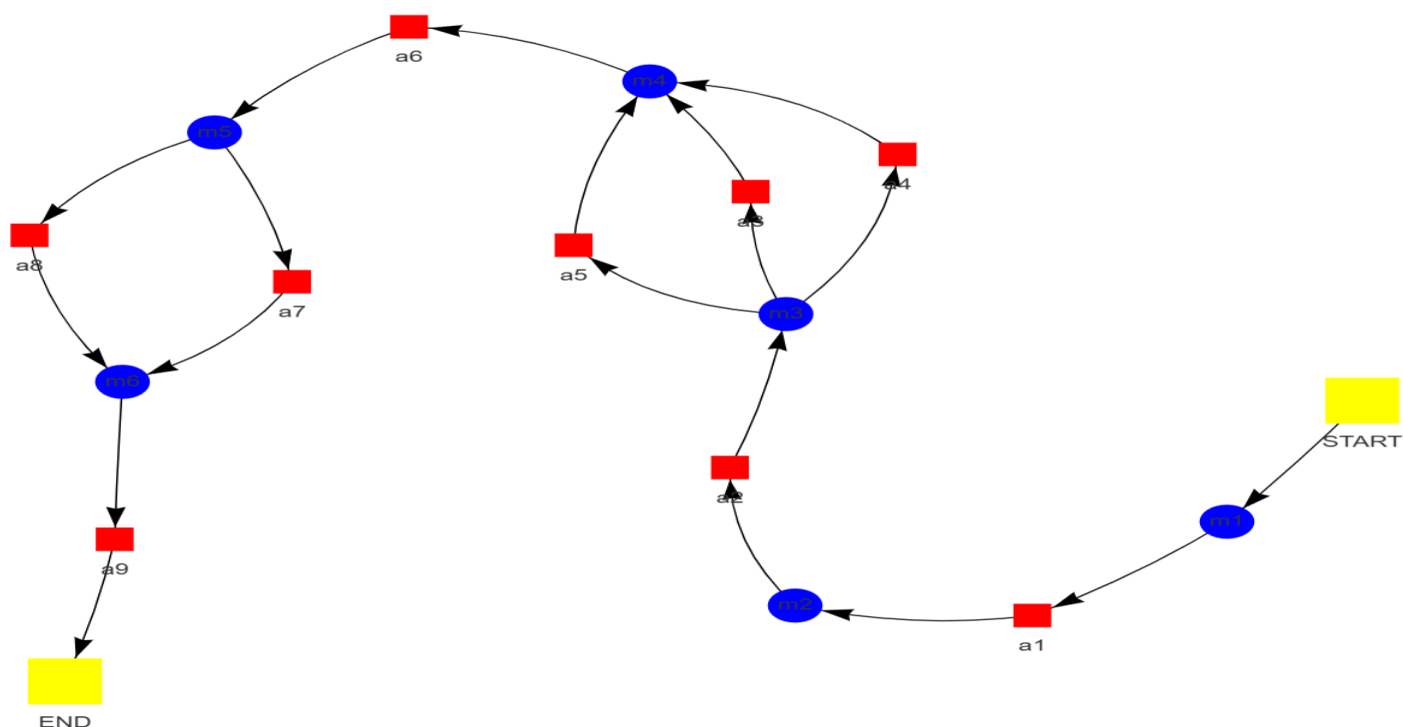
a7. Application Layer Protocol: Web Protocols as used by the malware (T1071.001)

a8. Fallback Channels as used by the malware (T1008)

Milestone m6

a9. Automated Exfiltration as used by the malware (T1020)

Attack Graph



Milestone *m1*

Attack Step *a1*

=====

Name: Supply Chain Compromise: Compromise Software Dependencies and Development Tools as used by the malware

Description: The supply chain is compromised through the following actions: Legitimate 3CX software components are Trojanized by the insertion of malicious code into ffmpeg.dll and d3dcompiler_47.dll. Software bearing this malicious code is signed using valid digital certificates and notarized by Apple (for macOS). Distribution of these compromised software components occurs through official 3CX channels.

Pre-Conditions:

- Access to the source code of 3CX Desktop App and its dependencies.
- Knowledge of the software development lifecycle used by 3CX.
- Secure communication channels for exfiltrating stolen data.
- A method for distributing the compromised code back to 3CX developers or users.
- Ability to modify the source code without detection.

Post-Conditions:

- Potential for further malware deployment and lateral movement within the network.
- Compromised 3CX Desktop App installations on user devices.
- Traces of data transfer within network traffic analysis.
- Altered registry entries related to the compromised application.
- Unusual system activity logs indicating suspicious processes and file access.
- Network connections to attacker-controlled domains.
- Damage to system integrity and stability.
- New configuration files created in the 3CX installation directory.
- Loss of sensitive information stored on affected devices.
- Data exfiltration from infected systems to attacker-controlled servers.

MITRE Technique

ID: T1195.001

Name: Supply chain compromise: compromise software dependencies and development tools

Description: Adversaries may manipulate software dependencies and development tools prior to receipt by a final consumer for the purpose of data or system compromise. Applications often depend on external software to function properly. Popular open source projects that are used as dependencies in many applications may be targeted as a means to add malicious code to users of the dependency.

More info: <https://attack.mitre.org/techniques/T1195/001>

Milestone *m2*

Attack Step a2

=====

Name: Compromise Client Software Binary as used by the malware

Description: The "Smooth Operator" malware exploits the MITRE ATT&CK; framework's T1195.001: Supply Chain Compromise tactic within the context of the 3CX attack. Compromised software dependencies are introduced into legitimate software packages, such as the 3CX desktop application, through manipulation of trusted software development processes. Distribution of these tainted installer packages occurs via official channels, leading to unwitting user execution upon installation. This tactic leverages trust in established software vendors and enables widespread dissemination and persistent malware presence within compromised systems.

Pre-Conditions:

- The 3CX client software is installed on a target system.
- The malware has access to the 3CX client software files.

Post-Conditions:

- Compromised 3CX Desktop App installations on affected systems.
- Network connections to attacker-controlled C2 servers.
- Altered system registry settings.
- Potential for further malware deployment and lateral movement within the network.
- Reputational damage to the organization if a breach is publicly disclosed.
- Data exfiltration from infected machines to attacker-controlled servers.
- Traces of data transfer to external locations.
- Modified timestamps in system logs.
- New files created in the 3CX installation directory, including shellcode and configuration files.
- Loss of system integrity and confidentiality.
- Logs containing suspicious activity related to the compromised application.

MITRE Technique

ID: T1574.001

Name: Hijack execution flow: dll

Description: Adversaries may abuse dynamic-link library files (DLLs) in order to achieve persistence, escalate privileges, and evade defenses. DLLs are libraries that contain code and data that can be simultaneously utilized by multiple programs. While DLLs are not malicious by nature, they can be abused through mechanisms such as side-loading, hijacking search order, and phantom DLL hijacking.

More info: <https://attack.mitre.org/techniques/T1574/001>

Milestone *m3*

Attack Step *a3*

=====

Name: Deobfuscate/Decode Files or Information as used by the malware

Description: The functionality of the malware, tentatively designated "Smooth Operator," is characterized by several sophisticated techniques. A supply chain attack forms the foundation of this operation, involving the compromise of a legitimate application (3CXDesktopApp) through the injection of malicious libraries during the build process. This methodology facilitates widespread dissemination within existing user bases. Custom encoding schemes are employed by Smooth Operator for both data exfiltration and internal communication with command-and-control (C2) servers. This practice renders traditional signature-based detection methods less effective. Dynamic task execution is another key characteristic, wherein the malware receives instructions (tasks) from the C2 server, which are executed dynamically. This adaptability allows attackers to tailor their actions based on the infected system's environment and objectives. A sleep timer mechanism is utilized by Smooth Operator to regulate its activity, while periodic beacons are sent to the C2 server to receive new instructions or provide progress reports. Deobfuscation and decoding techniques likely employed by the malware encompass multiple layers of obfuscation. Data encoding, utilizing a custom scheme specific to Smooth Operator, is crucial for understanding its communication with the C2 server and internal data processing. Reverse engineering of this algorithm is necessary to decipher the encoded messages. Shellcode execution, injected into d3dcompiler_47.dll, requires decoding and analysis to determine its purpose, such as downloading additional malware, stealing credentials, or establishing persistence.

Pre-Conditions:

- Access to files containing malware code is required.
- A computer system with internet connectivity.
- Tools capable of analyzing and deobfuscating binary code.
- Possibly access to a malware analysis sandbox environment.
- The malware utilizes obfuscation techniques to hide its true functionality.

Post-Conditions:

- New user accounts or processes created by the malware.
- Compromised 3CX Desktop App installations on affected devices.
- Modified .dmg files with embedded malicious code.
- Registry modifications related to malware persistence and execution.
- Log entries indicating communication with attacker-controlled C2 servers.
- Increased risk of ransomware infection or other malicious activities.
- Presence of "libffmpeg.dylib" file with injected malicious code.
- Altered 3CX Desktop App installation packages (.exe, .pkg).
- Potential for lateral movement and further compromise within the victim's network.
- Modified system configuration files.
- Data exfiltration from infected systems to attacker-controlled servers.

MITRE Technique

ID: T1140

Name: Deobfuscate/decode files or information

Description: Adversaries may use Obfuscated Files or Information to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

More info: <https://attack.mitre.org/techniques/T1140/>

Attack Step a4

=====

Name: Indicator Removal: File Deletion as used by the malware

Description: Indicator removal during the malware's second stage is effectuated through file deletion. Upon execution, the malicious code directly targets and deletes its own executable file from system storage. This action results in the primary evidence of its presence being removed, thereby hindering detection and analysis by security tools or investigators.

Pre-Conditions:

- The malware has identified the target file(s) to be deleted.
- Access permissions to delete the target file(s).
- The malware has successfully executed.
- Operating system with file deletion capabilities.

Post-Conditions:

- Data exfiltration from infected systems to attacker-controlled servers.
- Registry modifications related to malware execution.
- Altered system settings for persistence.
- Newly created log files with suspicious activity.
- Presence of malicious code in memory analysis.
- Network connections to unknown IP addresses.
- Modified 3CX application files (.dmg or .msi).
- Compromised 3CX software installations on affected systems.
- Reputational damage to 3CX and potentially affected users.
- Potential for further malicious activity on compromised systems.

MITRE Technique

ID: T1070.010

Name: Indicator removal: relocate malware

Description: Once a payload is delivered, adversaries may reproduce copies of the same malware on the victim system to remove evidence of their presence and/or avoid defenses. Copying malware payloads to new locations may also be combined with File Deletion to cleanup older artifacts.

More info: <https://attack.mitre.org/techniques/T1070/010>

Attack Step a5

=====

Name: Virtualization/Sandbox Evasion: Time Based Evasion as used by the malware

Description: Time-based evasion is a tactic employed by malware to defer malicious activities until a more advantageous juncture. This technique involves a deliberate delay in establishing communication

with command and control (C&C;) servers. Security solutions reliant on real-time monitoring may be rendered ineffective as malware remains dormant for extended periods, potentially evading detection. Furthermore, security analysts often prioritize immediate threats, leading to the potential oversight of malware exhibiting minimal initial activity. Upon successful infection, malware implementing this technique enters a quiescent state. After a predetermined interval, typically exceeding one week, the malware reactivates and initiates communication with its C&C; server to receive further instructions. The implementation of time-based evasion significantly complicates the detection process by security tools during the initial phase of infection. By the time the malware becomes active, it may have already established a secure foothold within the system and potentially compromised sensitive data, thereby increasing the difficulty of response efforts.

Pre-Conditions:

- The malware has the capability to modify its own execution behavior based on time-related factors.
- The malware is running within a virtualized or sandboxed environment.
- The system clock must be accessible to the malware.

Post-Conditions:

- Files with encoded strings related to communication with C&C; servers
- Network connections to malicious C&C; servers
- Log entries indicating suspicious activity
- dll) in the system directory
- Altered system registry settings
- Modified .main_storage file containing victim ID and beacon time
- Encrypted code within modified DLLs

MITRE Technique

ID: T1497.003

Name: Virtualization/sandbox evasion: time based evasion

Description: Adversaries may employ various time-based methods to detect and avoid virtualization and analysis environments. This may include enumerating time-based properties, such as uptime or the system clock, as well as the use of timers or other triggers to avoid a virtual machine environment (VME) or sandbox, specifically those that are automated or only operate for a limited amount of time.

More info: <https://attack.mitre.org/techniques/T1497/003>

Milestone *m4*

Attack Step *a6*

=====

Name: Automated Collection as used by the malware

Description: ICONStorages malware, also known as Smooth Operator, facilitates automated data collection through a multi-stage process. Initial infection is achieved via a supply chain compromise, wherein malicious code is injected into a dependency file (libffmpeg.dylib on macOS) within the legitimate 3CX software package. Upon execution of the 3CX application, the compromised library is loaded, initiating the first stage of Smooth Operator. The first stage downloads a second payload from a predetermined GitHub repository or command and control (C&C;) server. This second stage encompasses functions designed to gather various data types from the infected machine. These data types may include system information, hardware specifications, network configurations, user credentials, file system data, and network traffic analysis. Collected data is obfuscated using a custom encoding scheme involving multiple layers of encryption, hindering analysis by security tools. Communication with the C&C; server occurs through periodic "beacon" messages containing the encoded data.

Pre-Conditions:

- Network connectivity to the attacker's command and control server.
- Resources on the target system to execute the malware code and collect data.
- A compromised system with the malware installed.

Post-Conditions:

- New system processes running suspicious executables or libraries.
- Log files containing suspicious activity and error messages.
- System vulnerabilities exploited for further attacks.
- Presence of backdoor tools or malware remnants in system directories.
- Compromised 3CX application installed on user systems.
- Altered registry entries related to the compromised application.
- Unusual file access patterns and data transfers.
- Disruption of business operations and communication channels.
- Network traffic to unknown command-and-control servers.
- Malicious code execution and potential data exfiltration.
- Loss of sensitive information and data breaches.
- Modified system configuration settings.

MITRE Technique

ID: T1005

Name: Data from local system

Description: Adversaries may search local system sources, such as file systems, configuration files, local databases, or virtual machine files, to find files of interest and sensitive data prior to Exfiltration.

More info: <https://attack.mitre.org/techniques/T1005/>

Milestone *m5*

Attack Step a7

=====

Name: Application Layer Protocol: Web Protocols as used by the malware

Description: The malware designated as Smooth Operator, identified within the context of the 3CX supply chain attack, predominantly employs HTTPS (Hypertext Transfer Protocol Secure) for Command and Control (C2) communication. HTTPS is utilized to establish encrypted connections between infected machines and designated C2 servers. Data transmitted during these connections is encrypted, rendering it challenging for security tools to intercept and analyze. Smooth Operator's C2 servers were hosted across a range of domains, encompassing both legitimate-appearing and more suspicious entries. The specific domains implicated in the attack have since been decommissioned. Encrypted requests are sent from the malware to the C2 server, frequently containing encoded data or instructions. These requests may encompass: * Regular check-ins (beaconing) to receive new commands or updates from the C2 server. * Transmission of exfiltrated data (e.g., passwords, files) to the C2 server for analysis and potential exploitation by the attackers. Encrypted responses containing instructions or further communication are transmitted from the C2 server. The preference for HTTPS stems from its inherent security features: encryption obscures malware communication, hindering detection and analysis by security tools. Furthermore, the utilization of seemingly legitimate domains can facilitate the malware's integration with normal web traffic, thereby complicating identification as malicious.

Pre-Conditions:

- A functioning network interface is available to the malware.
- Access to the internet or a target server hosting the malicious content is required.
- The malware possesses the capability to parse and interpret web protocol data.

Post-Conditions:

- Network connections to attacker-controlled servers
- Remote access to the infected system
- Altered registry entries
- System instability and performance degradation
- New files created by the malware (backdoor, configuration files)
- Deleted or modified original files
- Data theft (system information, browser data)
- Installation of additional malware
- Modified system files
- Logs containing suspicious activity
- Browser history modifications

MITRE Technique

ID: T1071.001

Name: Application layer protocol: web protocols

Description: Adversaries may communicate using application layer protocols associated with web traffic to avoid detection/network filtering by blending in with existing traffic. Commands to the remote system, and often the results of those commands, will be embedded within the protocol traffic between

the client and server.

More info: <https://attack.mitre.org/techniques/T1071/001>

Attack Step a8

=====

Name: Fallback Channels as used by the malware

Description: Smooth Operator's communication with command and control (C2) servers is facilitated through a multi-stage approach incorporating fallback channels to ensure persistent connectivity. Initial infection typically occurs via a compromised version of the 3CX desktop application, leading to the installation of malware disguised as legitimate software. Stage 1 establishes communication with C2 servers primarily using HTTPS for receiving instructions and transmitting data. A list of multiple C2 domains is maintained by Smooth Operator, employing a fallback mechanism in case of server unavailability. For each beacon (communication attempt), a C2 domain is randomly selected from the pre-configured list. An HTTPS connection is then attempted with the chosen server. In the event of a connection failure, the process iterates to the next C2 domain until a successful connection is established. The utilization of fallback channels by malware such as Smooth Operator provides several advantages. Resilience is achieved as the malware can readily switch to alternative C2 servers if primary servers are compromised or taken down. Additionally, employing multiple domains complicates tracking and analysis of the command and control infrastructure, enhancing evasion capabilities. Understanding the implementation of fallback channels in malware like Smooth Operator is crucial for effective defense strategies. Continuous monitoring of networks for suspicious connections to known or suspected C2 domains is essential. Collaboration with security researchers and organizations through threat intelligence sharing platforms facilitates the dissemination of information regarding emerging C2 infrastructure and tactics. Implementing network segmentation practices can isolate critical systems from less secure networks, thereby mitigating the potential impact of a successful infection.

Pre-Conditions:

- The malware has established a primary communication channel with its command and control server.
- The malware is running.

Post-Conditions:

- Suspicious network connections to attacker-controlled servers.
- Data exfiltration from infected systems.
- Modified libffmpeg.dylib file on macOS systems.
- Compromised 3CX desktop application functionality.
- Potential for further malware deployment and lateral movement within the network.
- Modified config.json file within the 3CXDesktopApp folder.
- Logs indicating unusual activity, process creation, and data transfers.
- Presence of malicious files (e.g., ICONIC Stealer) in system directories.
- Loss of system control and integrity.
- Altered registry entries related to the compromised application.
- Reputational damage to affected organizations.
- YARA rule matches indicating Smooth Operator obfuscation techniques.

MITRE Technique

ID: T1008

Name: Fallback channels

Description: Adversaries may use fallback or alternate communication channels if the primary channel is compromised or inaccessible in order to maintain reliable command and control and to avoid data transfer thresholds.

More info: <https://attack.mitre.org/techniques/T1008/>

Milestone *m6*

Attack Step *a9*

=====

Name: Automated Exfiltration as used by the malware

Description: Automated exfiltration techniques are employed by malware to surreptitiously transfer sensitive data from compromised systems without user intervention. Data is typically collected from various sources on the infected system, including credentials, financial information, personal identifiers, system logs, and confidential files. To evade detection by security measures, the exfiltrated data is often encoded or obfuscated prior to transmission. Exfiltration channels utilized by malware encompass a range of methods, such as connections with command-and-control (C2) servers, email transmission, cloud storage services, secure file transfer protocols, and remote access tools. These techniques facilitate the clandestine movement of stolen data from the compromised system to external locations controlled by the attackers.

Pre-Conditions:

- A mechanism for transmitting the exfiltrated data to the C2 server.
- Network connectivity to the attacker-controlled C2 server.
- The malware has successfully infected a target system.
- The malware has established a connection to a command and control (C2) server.
- The malware has identified data to be exfiltrated.

Post-Conditions:

- Compromised user accounts
- Unusual network traffic logs
- System event logs indicating suspicious activity
- Hidden or renamed files
- Presence of malicious DLLs
- System instability and performance degradation
- Evidence of data exfiltration
- Modified system files
- Data theft (browser history, bookmarks, passwords)
- New registry entries
- Altered browser settings
- Remote access granted to attackers
- Potential for further malware infections

MITRE Technique

ID: T1020

Name: Automated exfiltration

Description: Adversaries may exfiltrate data, such as sensitive documents, through the use of automated processing after being gathered during Collection.

More info: <https://attack.mitre.org/techniques/T1020/>